

IT Compliance Standards (A Guide to the Basics)

Source: <https://www.indeed.com/career-advice/career-development/it-compliance>

Meeting information technology (IT) compliance standards is critical for businesses that use electronic systems to collect and store data, have an online identity or promote digital services.

IT compliance standards help protect private information and maintain customer trust.

These standards differ by industry and company, so learning about common IT compliance standards can assist you in determining which regulations apply.

What is IT compliance?

IT compliance is when businesses meet all the legal requirements, standards and regulations for the software their company uses to safeguard customer data.

Achieving these standards means following all industry regulations, government policies, security frameworks and customer terms of agreement to ensure software security and appropriate usage in business.

In addition to protecting the security of businesses and customers, compliance standards promote the availability and reliability of services and ensure that businesses use the software as intended.

The standards for IT compliance vary by industry. For example, companies in the health care and finance industries must meet industry-specific compliance laws to protect themselves and their customers. In health care, organizations must follow legal guidelines that protect the privacy and confidentiality of their patients when using digital health care services or storing medical records electronically.

Businesses conducting e-commerce need to meet specific regulations to store, process and transmit customers' payment information safely.

Other compliance expectations can vary by the size of the business and the customers it serves.

Why is IT compliance important?

IT compliance is important for protecting the privacy and security of customers, clients, employees and companies and for increasing the trust that customers have in a business. When businesses adhere to high digital security and privacy standards through compliance metrics, customers may feel more secure when using their services and invite others to use the services as well.

Customers or clients generally want to know that their private information, such as social security numbers, medical records and bank account information, is secure.

Meeting compliance standards means that a company complies with legal requirements, reducing the risk of facing legal penalties, paying fines or losing opportunities to conduct business in geographic areas with specific compliance regulations.

6 common IT compliance standards

Here are some common compliance standards to consider for IT businesses or organizations:

1. GDPR

The General Data Protection Regulation (GDPR) is a set of IT regulations that the European Union (EU) enforces. The GDPR regulations protect the digital information of European citizens, and any business that collects data related to EU citizens must comply with GDPR compliance standards. This means that if companies or individual sellers from the United States wish to offer goods or services, they must comply with GDPR if they monitor the behavior of EU residents.

One example of GDPR regulation is obtaining permission from individual users to collect their data. This regulation ensures that businesses inform users when companies manage their data and those users have the option to decline if they prefer to keep their information private. When a user opens a webpage, they have the option of agreeing or declining. If the user declines, the company must delete any gathered data. [GDPR Checklist: <https://gdpr.eu/checklist/>]

2. PCI DSS

The Payment Card Industry Data Security Standard (PCI DSS) governs the security of financial card data, such as debit and credit card numbers. The PCI DSS applies to any business that conducts online transactions that require the storage, transmission and management of a user's financial information.

Companies that adhere to the PCI DSS must promote transparency and trust with clients who conduct transactions through their web services.

When customers learn that a company meets PCI DSS standards, they may feel more secure when using the online services. Businesses often develop active systems that host and protect customer financial information to meet the PCI DSS standards.

[PCI DSS Checklist: <https://nordlayer.com/learn/pci-dss/compliance-checklist/>]

3. SOX

The Sarbanes-Oxley Act (SOX) is another financial compliance standard. SOX requires complete and transparent disclosure of a company's financial information, and any publicly traded company or industry launching an initial public offering must meet this standard.

The SOX standard requires companies to disclose complete and accurate financial information so that stakeholders can make informed decisions about whether to invest in a business.

In addition to safeguarding stakeholders, SOX may discourage fraud, reduce the risk of accounting errors and help businesses improve their earnings reporting while streamlining their workflows.

[SOX Compliance Checklist: <https://www.exabeam.com/explainers/sox-compliance/sox-compliance-requirements-and-checklist/>]

4. HIPAA

The Health Insurance Portability and Accountability Act (HIPAA) ensures the security of patient health records in the health care industry. It applies to all businesses and organizations that handle, access or transfer medical records. These organizations include medical facilities such as clinics, hospitals, pharmacies and third-party providers, like insurance companies.

HIPAA compliance policies include:

- Maintaining privacy regulations that restrict sharing medical information without direct patient consent
- Ensuring that businesses fully secure electronic files by implementing administrative, physical and technical structures that prevent unauthorized individuals from accessing patient information
- Installing a notification system that immediately alerts businesses and patients in case of a security breach or threat

5. GLBA

The Gramm- Leach-Bliley Act (GLBA) applies to financial institutions that offer investment or financial advice, insurance or loans to clients. For instance, financial advisory firms, real estate firms and universities must adhere to GLBA.

This regulation requires institutions to disclose how they protect their customers' data and what information-sharing policies they have in place.

To abide by this regulation, financial institutions must disclose their policies and request that customers and clients opt into their services. Customers can choose not to have their information shared with certain third parties by opting out of this.

6. FISMA

The Federal Information Security Management Act (FISMA) applies to federal agencies and mandates the implementation of information security plans to safeguard sensitive information.

This act requires federal agencies to develop data protection plans and promotes different types of security software and systems while also verifying third-party vendors. FISMA also takes into account the various security requirements of other federal departments.

One example of FISMA is government agencies devoted to national security, as they must meet a higher standard of compliance than those working for the U.S. Department of Housing and Urban Development, for instance.

While government agencies must comply with FISMA, businesses that work with government agencies may also need to be aware of these regulations.